

Отчет по лабораторной работе №3

Дисциплина: Кибербезопасность предприятия

Боровиков Даниил	Хрусталев Влад
Гисматуллин Артём	Чесноков Артёмий
Коннова Татьяна	Нефедова Наталья
Уткина Алина	Бансимба Клодели

Содержание

1 Введение	5
1.1 Используемые инструменты	5
2 Уязвимый узел: WpDiscuz	6
2.1 Описание уязвимости	6
2.1.1 Обнаружение уязвимости	6
2.2 Эксплуатация и последствия	6
2.3 Устранение уязвимости	7
2.3.1 Проверка устранения	11
3 Уязвимый узел: RocketChat	12
3.1 Описание уязвимостей	12
3.2 Обнаружение уязвимостей	12
3.3 Эксплуатация и последствия	12
3.4 Устранение уязвимостей	13
3.5 Проверка устранения	20
4 Уязвимый узел: Proxylogon	21
4.1 Описание уязвимостей	21
4.2 Обнаружение уязвимостей	21
4.3 Эксплуатация и последствия	21
4.4 Устранение уязвимостей	22
4.5 Проверка устранения	24
5 Общие выводы	25

Список иллюстраций

2.1	Вредоносные файлы	7
2.2	Активная версия плагина	8
2.3	Восстановление из резервной копии	9
2.4	Восстановление из резервной копии	10
2.5	Восстановление из резервной копии	10
2.6	Завершение вредоносных соединений	11
3.1	Несанкционированные подключения	12
3.2	Создание backdoor-соединений 2	13
3.3	Сброс пароля администратора	14
3.4	Сброс пароля администратора 2	15
3.5	Настройка	16
3.6	Настройка	17
3.7	Настройка	18
3.8	Отключение выполнения JavaScript в MongoDB	19
3.9	Восстановление базы данных	20
4.1	Установка meterpreter-сессий	21
4.2	Блокировка доступа	22
4.3	Блокировка доступа	23
4.4	Завершение вредоносных процессов	23
5.1	Выполнение работы	26
5.2	Заполнение инцидентов	26

Список таблиц

1 Введение

В рамках лабораторной работы проведен анализ трех уязвимых узлов с различными типами уязвимостей. Использовались инструменты мониторинга и защиты: ViPNet IDS NS, Security Onion, а также встроенные средства операционных систем для обнаружения и нейтрализации атак.

1.1 Используемые инструменты

- **ViPNet IDS NS** - обнаружение сетевых атак
 - **Security Onion** - мониторинг сетевой безопасности
 - **Системные утилиты** (ss, netstat, taskkill) - анализ процессов и соединений
-

2 Уязвимый узел: WpDiscuz

2.1 Описание уязвимости

CVE-2020-24186 - уязвимость удаленного выполнения кода в плагине WordPress WpDiscuz версий 7.0.0-7.0.4. Позволяет загружать произвольные PHP-файлы через функционал комментариев без аутентификации.

2.1.1 Обнаружение уязвимости

- Обнаружена активная версия плагина 7.0.2 (рис. 2.2)
- Выявлены вредоносные файлы в директории веб-сервера (рис. 2.1)

2.2 Эксплуатация и последствия

- Устранение backdoor-файлов (AM_Backdoor.aspx) (рис. 2.1)
- Установление обратных соединений с хостом нарушителя
- Изменение содержимого веб-сайта

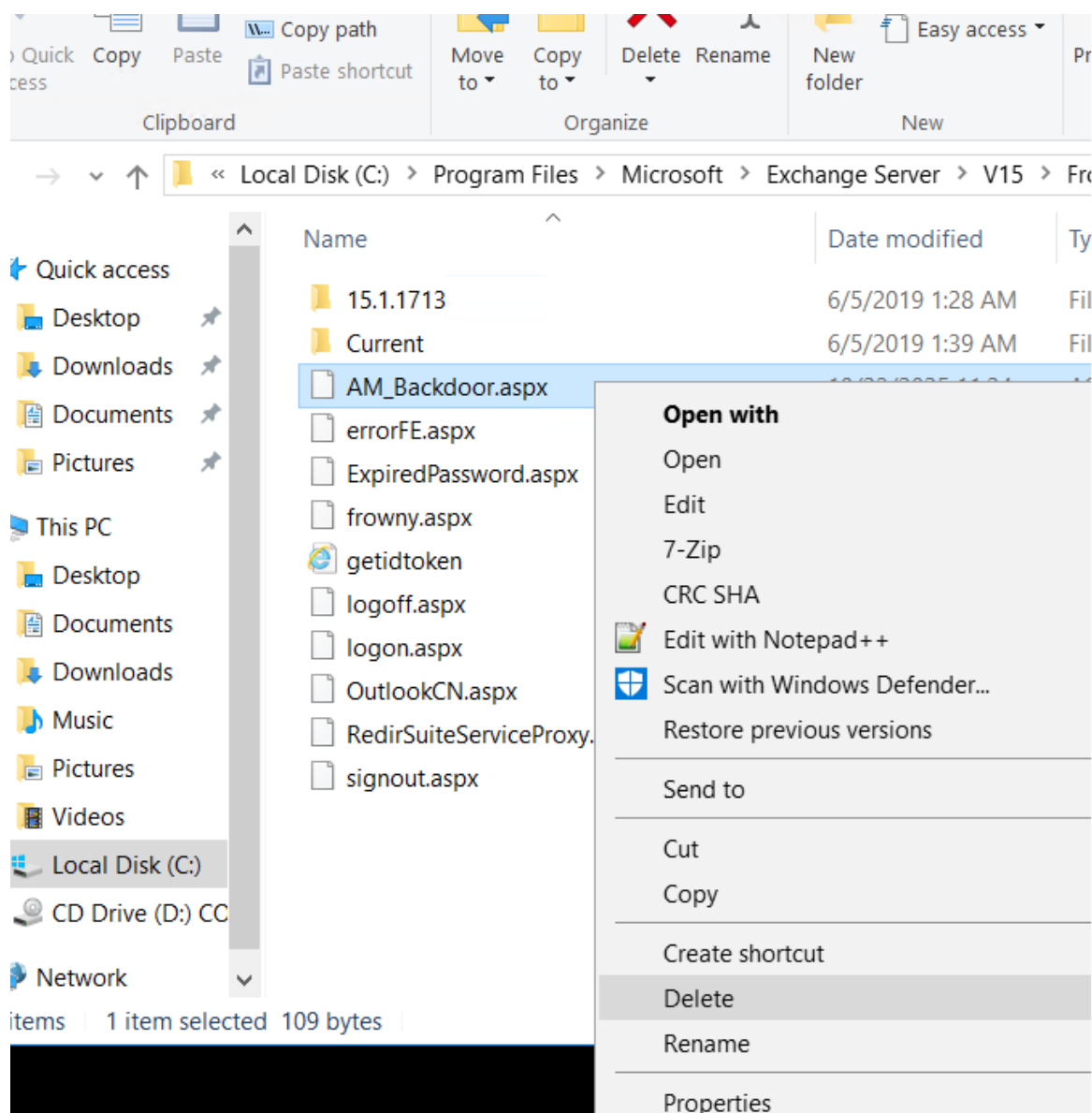


Рис. 2.1: Вредоносные файлы

2.3 Устранение уязвимости

1. **Деактивация уязвимого плагина** (рис. 2.2)
2. **Восстановление из резервной копии** через плагин UpdraftPlus (рис. 2.3, рис. 2.4, (рис. 2.5)

3. Завершение вредоносных соединений:

```
sudo kill 1840
```

```
sudo kill 1873
```

```
sudo kill 1874
```

```
sudo ss -tmp
```

(рис. 2.6)

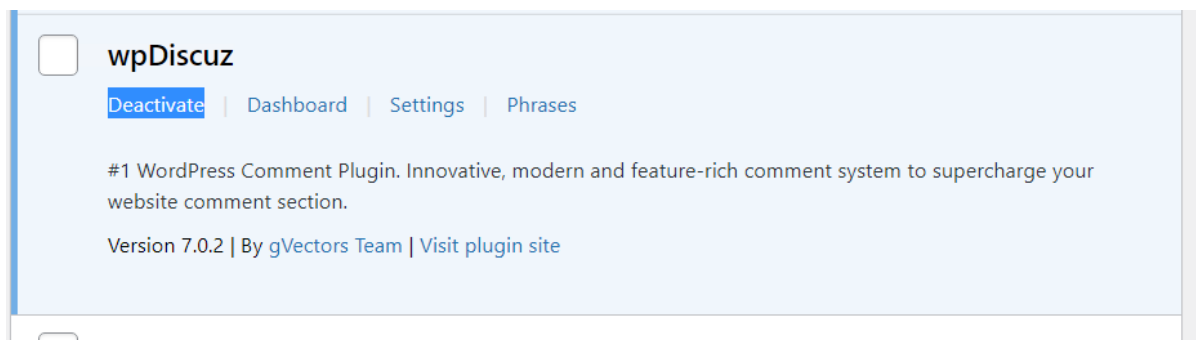


Рис. 2.2: Активная версия плагина

The restore operation has begun (91d7aa1f21cc). Do not close this page until it reports itself as having finished.

✗ Restore failed...

[Return to UpdraftPlus configuration](#)

[Follow this link to download the log file for this restoration \(needed for any support requests\).](#)

Activity log



Final checks

Looking for themes archive: file name: backup_2023-09-15-0849_webportal3ampirecorp_00140c92e515-themes.zip

Archive is expected to be size: 6541.6 KB: OK

Error: Existing unremoved folders from a previous restore exist (please use the "Delete Old Directories" button to delete them before trying again): /var/www/html/wordpress/wp-content/updraft/themes-old

[Delete Old Directories](#)

Restore failed...

- Error: Existing unremoved folders from a previous restore exist (please use the "Delete Old Directories" button to delete them before trying again): /var/www/html/wordpress/wp-content/updraft/themes-old

Actions: [Return to UpdraftPlus configuration](#)

Рис. 2.3: Восстановление из резервной копии

UpdraftPlus Restoration — Restore files from: Sep 15, 2023 8:49

Restoring will replace this site's themes, plugins, uploads, database and/or other content directories (according to what is contained in the backup set, and your selection). Choose the components to restore:

[Do read this helpful article of useful things to know before restoring.](#)

Choose the components to restore:

☐ Plugins

☒ Themes

☒ Uploads

☐ Others

☐ Database

Cancel

Next

Рис. 2.4: Восстановление из резервной копии

☐

Backup date

Sep 15, 2023 8:49

Backup data (click to download)

Database

Plugins

Themes

Uploads

Others

Actions

Restore

Upload

Delete

View Log

Рис. 2.5: Восстановление из резервной копии

```
user@web-portal-3: ~
ESTAB      0      0      10.10.1.22:59618      195.239.174.11:5556
users: (("chisel.sh",pid=1874,fd=3), ("sh",pid=1873,fd=3), ("VwUKd",pid=1840,fd=3)
)
ESTAB      0      0      10.10.1.22:57628      195.239.174.11:1085
users: (("chisel.sh",pid=1874,fd=11))
CLOSE-WAIT1      0      10.10.1.22:39898      195.239.174.11:5557
users: (("chisel.sh",pid=1874,fd=12), ("sh",pid=1873,fd=12), ("VwUKd",pid=1840,fd=
12))
ESTAB      0      0      [::ffff:10.10.1.22]:80      [::ffff:10.10.1.253]:51029
users: (("apache2",pid=6967,fd=11))
user@web-portal-3:~$ sudo kill 1840
user@web-portal-3:~$ sudo ss -tnp
State      Recv-Q      Send-Q      Local Address:Port      Peer Address
ESTAB      0      64      10.10.1.22:22      10.10.1.253
users: (("sshd",pid=8093,fd=3), ("sshd",pid=7927,fd=3))
FIN-WAIT-2      0      0      10.10.1.22:49492      10.10.2.11
users: (("chisel.sh",pid=1874,fd=16))
ESTAB      0      0      10.10.1.22:59618      195.239.174.11
users: (("chisel.sh",pid=1874,fd=3), ("sh",pid=1873,fd=3))
ESTAB      0      0      10.10.1.22:57628      195.239.174.11
users: (("chisel.sh",pid=1874,fd=11))
CLOSE-WAIT      1      0      10.10.1.22:39898      195.239.174.11
users: (("chisel.sh",pid=1874,fd=12), ("sh",pid=1873,fd=12))
ESTAB      0      0      [::ffff:10.10.1.22]:80      [::ffff:10.10.1.253]
users: (("apache2",pid=6965,fd=11))
user@web-portal-3:~$ sudo kill 1873
user@web-portal-3:~$ sudo kill 1874
user@web-portal-3:~$ sudo ss -tnp
State      Recv-Q      Send-Q      Local Address:Port      Peer Address
ESTAB      0      64      10.10.1.22:22      10.10.1.253
users: (("sshd",pid=8093,fd=3), ("sshd",pid=7927,fd=3))
FIN-WAIT-2      0      0      10.10.1.22:49492      10.10.2.11
LAST-ACK      1      1      10.10.1.22:39898      195.239.174.11
ESTAB      0      0      [::ffff:10.10.1.22]:80      [::ffff:10.10.1.253]
users: (("apache2",pid=1098,fd=11))
user@web-portal-3:~$ sudo ss -tnp
State      Recv-Q      Send-Q      Local Address:Port      Peer Address
ESTAB      0      64      10.10.1.22:22      10.10.1.253
users: (("sshd",pid=8093,fd=3), ("sshd",pid=7927,fd=3))
LAST-ACK      1      1      10.10.1.22:39898      195.239.174.11
```

Рис. 2.6: Завершение вредоносных соединений

2.3.1 Проверка устранения

- Отсутствие активных соединений с хостом нарушителя
- Восстановлена оригинальная версия сайта
- Плагин деактивирован или обновлен

3 Уязвимый узел: RocketChat

3.1 Описание уязвимостей

1. **CVE-2021-22911** - NoSQL-инъекция, позволяющая повышение привилегий
2. **CVE-2022-0847** (Dirty Pipe) - уязвимость повышения привилегий в ядре Linux

3.2 Обнаружение уязвимостей

- Обнаружены подозрительные запросы в логах RocketChat
- Выявлены несанкционированные подключения к БД (рис. 3.1)

353

1

1

10:56:47

ET DOS Microsoft Remote Desktop (RDP) Syn then Reset 30 Second DoS Attempt

2014384

6

11.563%

alertrtcn any any -> \$HOME_NET 3389 (msg:"ET DOS Microsoft Remote Desktop (RDP) Syn then Reset 30 Second DoS Attempt"; flags:R; flow:to_server; flowbits:isset,ms.rdp.synack; flowbits:isnotset,ms.rdp.established; flowbits:unset,ms.rdp.synack; reference:cve,2012-0152; classtype:attempted-dos; sid:2014384; rev:8; metadata:created_at 2012_03_13, updated_at 2012_03_13;)

file: downloaded.rules:9949

☒

CATEGORIZE

353

EVENT(S)

CREATE FILTER:

src

dst

both

QUEUE	ACTIVITY	LAST EVENT	SOURCE	AGE	COUNTRY	DESTINATION	AGE	COUNTRY
353		2025-10-09 10:58:36	195.239.174.11	0	RUSSIAN FEDERATION (.ru)	10.10.4.11	0	RFC1918 (.lo)

Рис. 3.1: Несанкционированные подключения

3.3 Эксплуатация и последствия

- Несанкционированный доступ к учетной записи администратора
- Создание backdoor-соединений (рис. 3.2)
- Модификация системных файлов

```

root@rocket-chat-server:/home/admin# ss -tp | grep "195."
ESTAB 0 0 10.10.2.22:45662 195.239.174.11:5559
users: ("testsystem",pid=1941,fd=3))
root@rocket-chat-server:/home/admin# dd -K dst 195.239.174.11 fport = 5559
dd: invalid option -- 'K'
Try 'dd --help' for more information.
root@rocket-chat-server:/home/admin# ss -K dst 195.239.174.11 fport = 5559
Error: an inet prefix is expected rather than "fport".
Cannot parse dst/src address.
root@rocket-chat-server:/home/admin# ss -K dst 195.239.174.11 port = 5559
Error: an inet prefix is expected rather than "port".
Cannot parse dst/src address.
root@rocket-chat-server:/home/admin# ss -K dst 195.239.174.11 dport = 5559
Netid State Recv-Q Send-Q Local Address:Port Peer Address:Port Process
tcp ESTAB 0 0 10.10.2.22:45662 195.239.174.11:5559
root@rocket-chat-server:/home/admin# █

```

Рис. 3.2: Создание backdoor-соединений 2

3.4 Устранение уязвимостей

1. **Сброс пароля администратора** через почтовое уведомление (рис. 3.3, рис. 3.4)

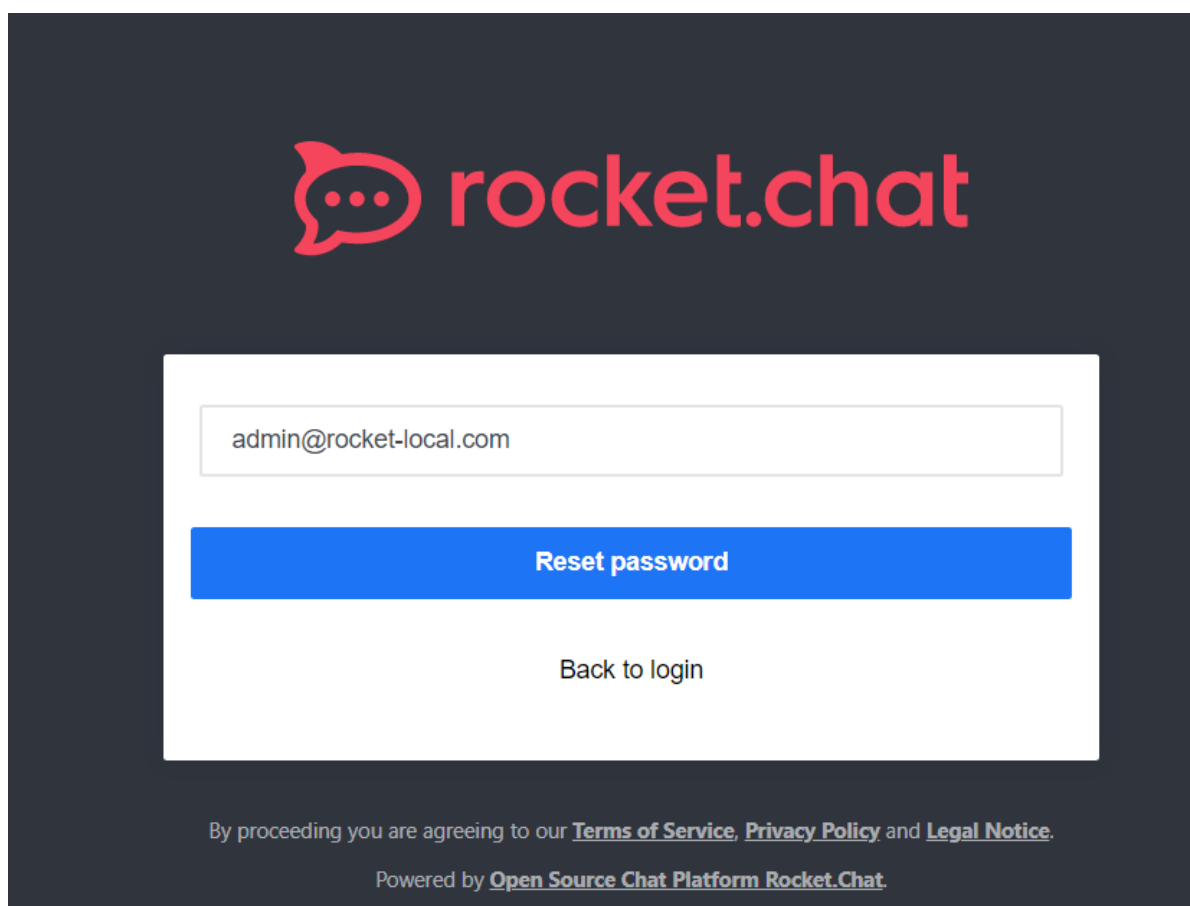


Рис. 3.3: Сброс пароля администратора

```
admin@rocket-chat-server: /var/mail
boundary="--_NmP-58eda74a15b4bb88-Part_1"
From: "Rocket.Chat" <rocketchat@rocket-local.com>
To: admin@rocket-local.com
Subject: Rocket.Chat - Password Recovery
Message-ID: <80abe8c6-fcc4-2598-0342-d673658ee558@rocket-local.com>
Date: Thu, 23 Oct 2025 12:01:46 +0000
MIME-Version: 1.0

----_NmP-58eda74a15b4bb88-Part_1
Content-Type: text/plain
Content-Transfer-Encoding: quoted-printable

Hello,

To reset your password, simply click the link below.

http://10.10.2.22:3000/reset-password/Cq_qImxSQ1QH51Xuc6UqOV1bGAmP8CjRhLm-A=
YjWZBa

Thanks.

----_NmP-58eda74a15b4bb88-Part_1
Content-Type: text/html; charset=utf-8
Content-Transfer-Encoding: quoted-printable
```

Рис. 3.4: Сброс пароля администратора 2

2. Настройка двухфакторной аутентификации (рис. 3.5, рис. 3.6, рис. 3.7)

maximum Delta

1

The Maximum Delta determines how many tokens are valid at any given time. Tokens are generated every 30 seconds, and are valid for $(30 * \text{Maximum Delta})$ seconds. Example: With a Maximum Delta set to 10, each token can be used up to 300 seconds before or after its timestamp. This is useful when the client's clock is not properly synchronized with the server.



Enable Two Factor Authentication via Email

Users with email verified and the option enabled in their profile page will receive a temporary code to authorize certain actions like login, save the profile, etc.



Auto opt in new users for Two Factor via Email

New users will have the Two Factor Authentication via Email enabled by default and will be able to disable it in their profile page.

Time to expire the code sent via email in seconds

3000

Рис. 3.5: Настройка

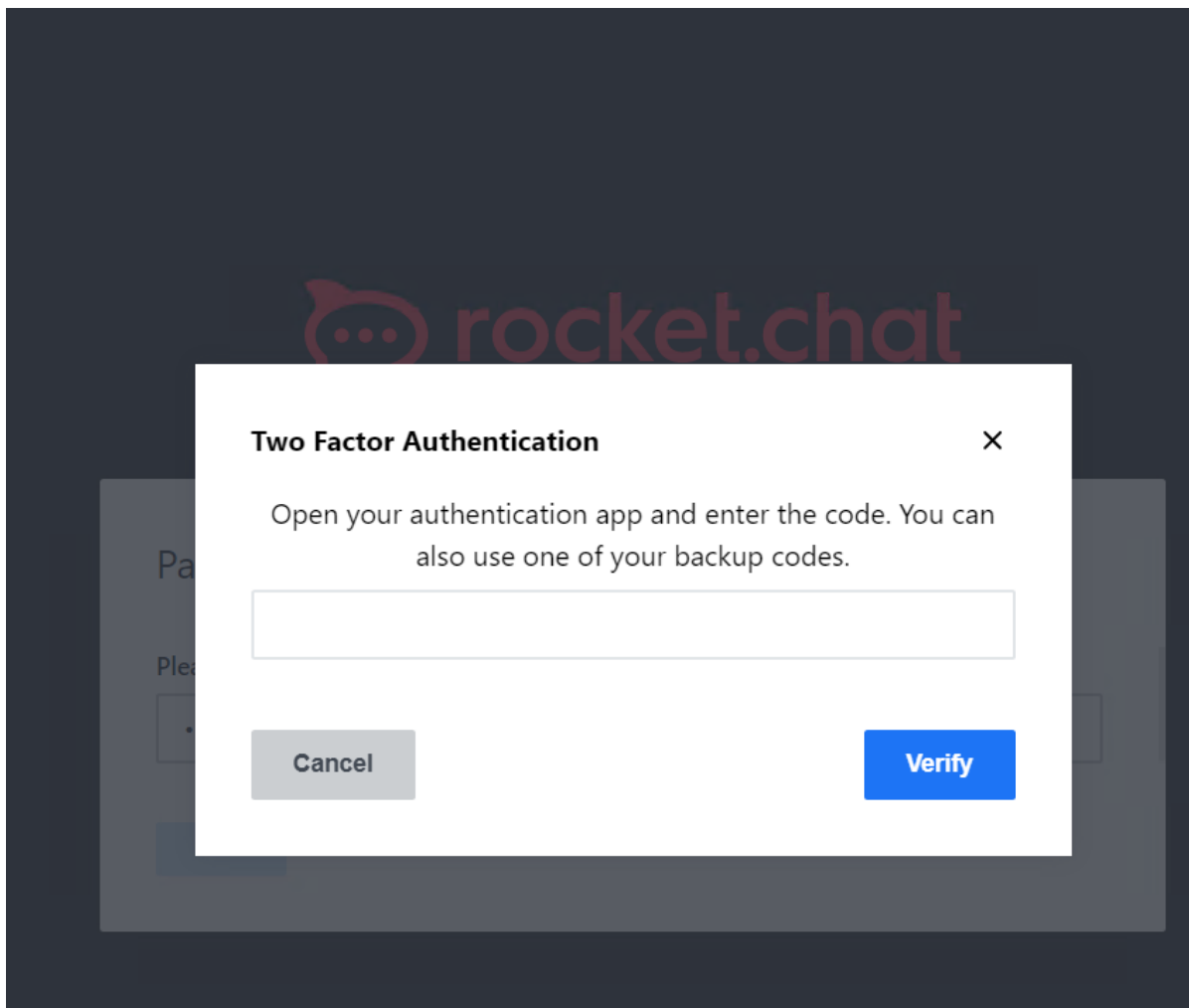


Рис. 3.6: Настройка

Role Editing

Role

user

Description

Description

Leave the description field blank if you dont want to show the role

Scope

Global

Users must use Two Factor Authentication

Save

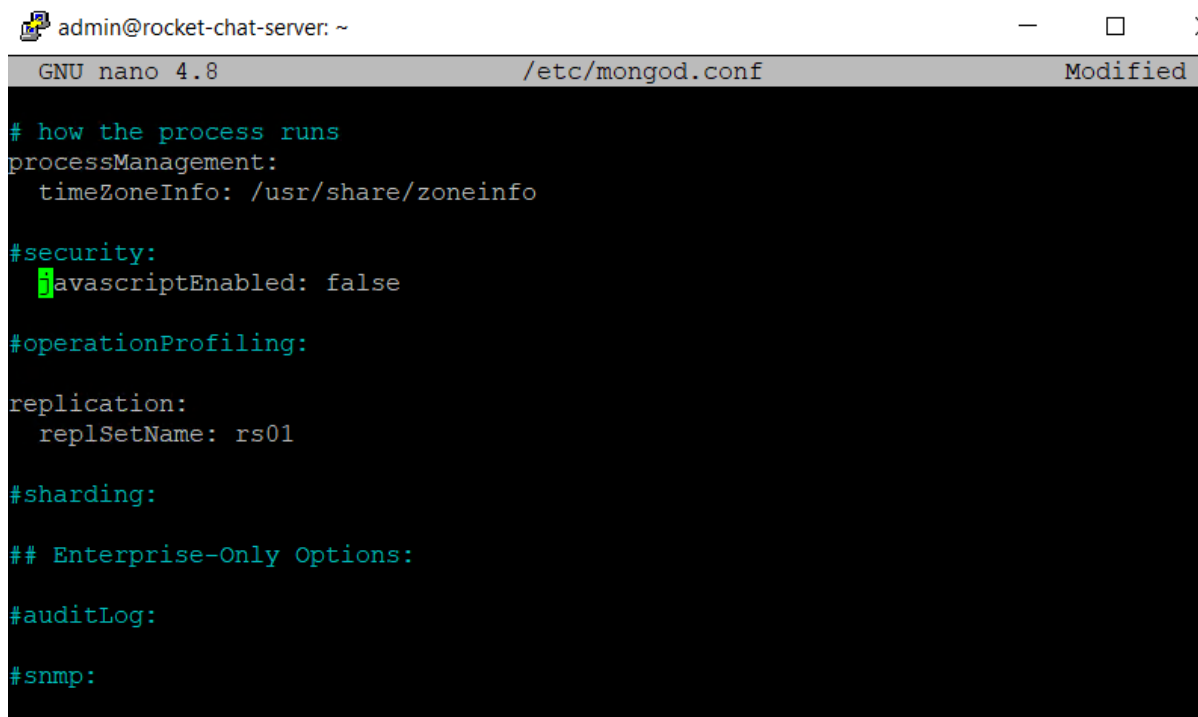
Users in role

Рис. 3.7: Настройка

3. Отключение выполнения JavaScript в MongoDB:

```
security:  
  javascriptEnabled: false
```

(рис. 3.8)



```
admin@rocket-chat-server: ~
GNU nano 4.8 /etc/mongod.conf Modified

# how the process runs
processManagement:
  timeZoneInfo: /usr/share/zoneinfo

#security:
  javascriptEnabled: false

#operationProfiling:

replication:
  replSetName: rs01

#sharding:

## Enterprise-Only Options:

#auditLog:

#snmp:
```

Рис. 3.8: Отключение выполнения JavaScript в MongoDB

4. Восстановление базы данных из резервной копии:

```
sudo systemctl stop rocketchat.service
mongo rocketchat --eval "db.dropDatabase()"
sudo mongorestore --db rocketchat --drop /var/backups/mongobackups/rocketchat
```

(рис. 3.9)

```

root@rocket-chat-server: /home/admin
root@rocket-chat-server:/home/admin# ss -K dst 195.239.174.11 fport = 5559
Error: an inet prefix is expected rather than "fport".
Cannot parse dst/src address.
root@rocket-chat-server:/home/admin# ss -K dst 195.239.174.11 port = 5559
Error: an inet prefix is expected rather than "port".
Cannot parse dst/src address.
root@rocket-chat-server:/home/admin# ss -K dst 195.239.174.11 dport = 5559
Netid State Recv-Q Send-Q Local Address:Port Peer Address:Port Process
tcp ESTAB 0 0 10.10.2.22:45662 195.239.174.11:5559
root@rocket-chat-server:/home/admin# sudo nano /etc/mongod.conf
root@rocket-chat-server:/home/admin# sudo systemctl stop rocketchat.service
root@rocket-chat-server:/home/admin# mongo rocketchat --eval "db.dropDatabase()"
MongoDB shell version v4.2.19
connecting to: mongodb://127.0.0.1:27017/rocketchat?compressors=disabled&gssapiServiceName=mongodb
Implicit session: session { "id" : UUID("250a58d8-dff9-4fe9-9d54-d5822e770a77")
}
MongoDB server version: 4.2.19
{
  "dropped" : "rocketchat",
  "ok" : 1,
  "$clusterTime" : {
    "clusterTime" : Timestamp(1761222028, 73),
    "signature" : {
      "hash" : BinData(0,"AAAAAAAAAAAAAAAAAAAAAAAAAA="),
      "keyId" : NumberLong(0)
    }
  },
  "operationTime" : Timestamp(1761222028, 73)
}
root@rocket-chat-server:/home/admin# sudo mongorestore --db rocketchat --drop /var/backups/mongobackups/rocketchat
2025-10-23T12:21:07.259+0000 the --db and --collection args should only be used when restoring from a BSON file. Other uses are deprecated and will not exist in the future; use --nsInclude instead
2025-10-23T12:21:07.260+0000 building a list of collections to restore from /var/backups/mongobackups/rocketchat dir
2025-10-23T12:21:07.266+0000 reading metadata for rocketchat.rocketchat_settings from /var/backups/mongobackups/rocketchat/rocketchat_settings.metadata.json
2025-10-23T12:21:07.267+0000 reading metadata for rocketchat.rocketchat_permissions from /var/backups/mongobackups/rocketchat/rocketchat_permissions.metadata

```

Рис. 3.9: Восстановление базы данных

3.5 Проверка устранения

- Успешная аутентификация с двухфакторной проверкой
- Отсутствие вредоносных соединений
- Корректная работа всех функций RocketChat

4 Уязвимый узел: Proxylogon

4.1 Описание уязвимостей

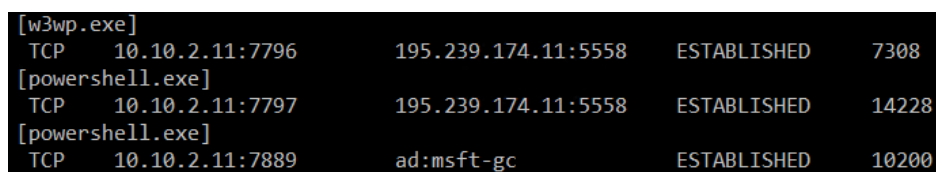
1. **CVE-2021-26855** - SSRF-уязвимость в Exchange Server
2. **CVE-2021-27065** - возможность записи файлов в произвольные директории

4.2 Обнаружение уязвимостей

- Выявлены подозрительные запросы к /еср (рис. 3.1)
- Обнаружены backdoor-файлы в системных директориях

4.3 Эксплуатация и последствия

- Создание веб-оболочек (China Chopper)
- Установление meterpreter-сессий (рис. 4.1)
- Модификация реестра Windows
- Создание вредоносных служб



[w3wp.exe]	TCP	10.10.2.11:7796	195.239.174.11:5558	ESTABLISHED	7308
[powershell.exe]	TCP	10.10.2.11:7797	195.239.174.11:5558	ESTABLISHED	14228
[powershell.exe]	TCP	10.10.2.11:7889	ad.msft-gc	ESTABLISHED	10200

Рис. 4.1: Установление meterpreter-сессий

4.4 Устранение уязвимостей

1. **Блокировка доступа к /еср** через IP restrictions в IIS (рис. 4.2, (рис. 4.3))

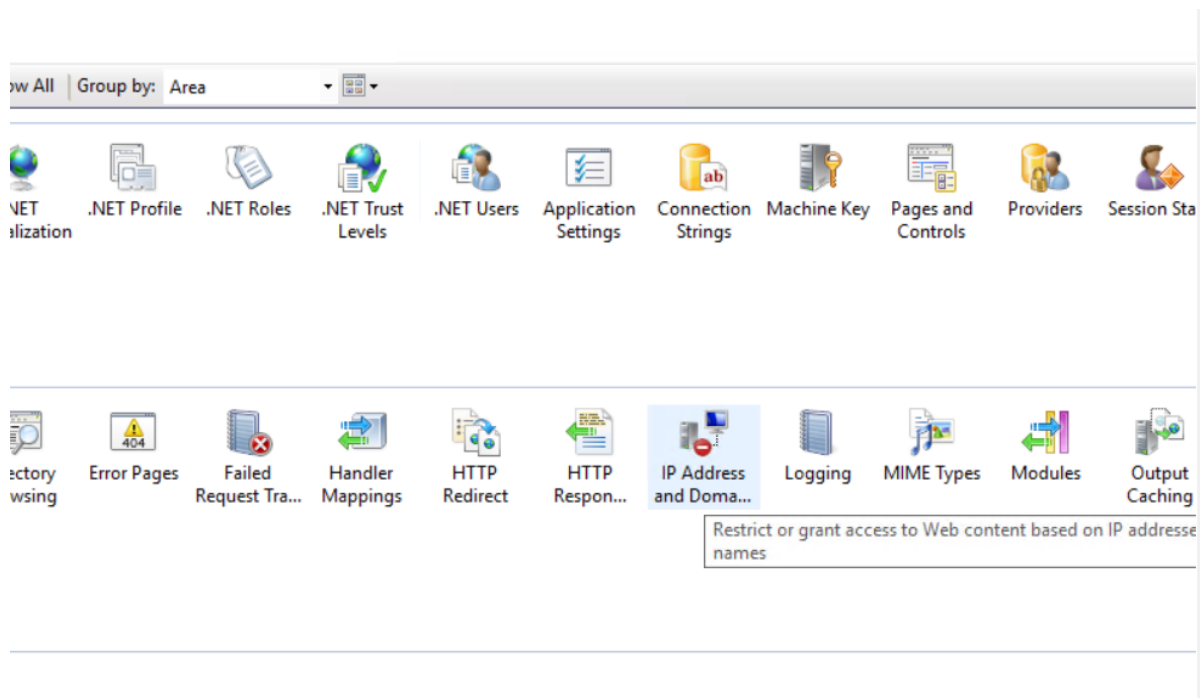


Рис. 4.2: Блокировка доступа

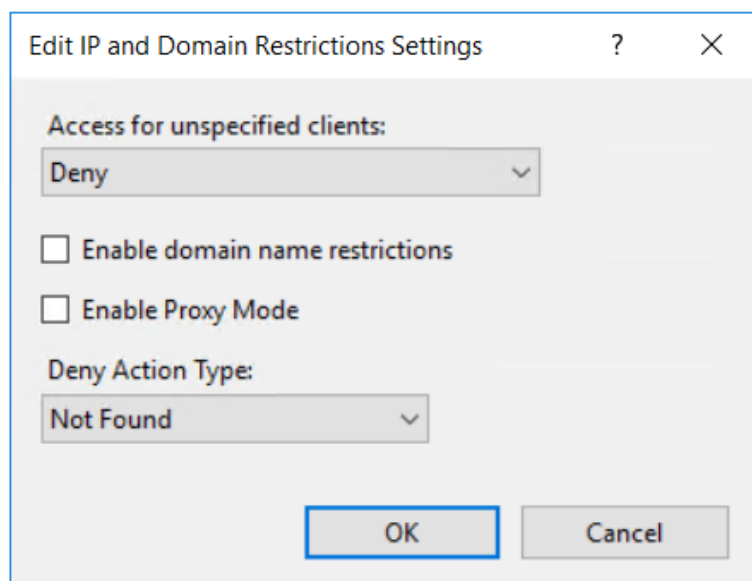


Рис. 4.3: Блокировка доступа

2. Завершение вредоносных процессов:

```
taskkill /PID 7308 /F
```

```
taskkill /PID 14228 /F
```

(рис. 4.4)

```
C:\Users\administrator.AMPIRE>cc  
  
C:\Users\administrator.AMPIRE>taskkill /PID 7308 /F  
SUCCESS: The process with PID 7308 has been terminated.  
  
C:\Users\administrator.AMPIRE>taskkill /PID 14228 /F  
SUCCESS: The process with PID 14228 has been terminated.  
  
C:\Users\administrator.AMPIRE>_
```

Рис. 4.4: Завершение вредоносных процессов

3. Удаление **backdoor-файлов** из системных директорий

4.5 Проверка устранения

- Отсутствие несанкционированных подключений
 - Невозможность доступа к /еср извне
 - Отсутствие вредоносных файлов и процессов
-

5 Общие выводы

В ходе лабораторной работы успешно проанализированы и нейтрализованы уязвимости трех различных веб-приложений:

1. **WpDiscuz** - уязвимость типа RCE через загрузку файлов
2. **RocketChat** - комбинация NoSQL-инъекции и уязвимости ядра ОС
3. **Proxylogon** - комплексная атака на Exchange Server

Ключевые результаты: - Освоены методы обнаружения и анализа различных типов уязвимостей - Приобретены навыки работы с системами мониторинга (ViPNet IDS NS, Security Onion) - Отработаны методики устранения последствий компрометации - Получен опыт восстановления систем после кибератак

Отчет о выполненной работе (рис. 5.1) и заполненных инцидентов (рис. 5.2)

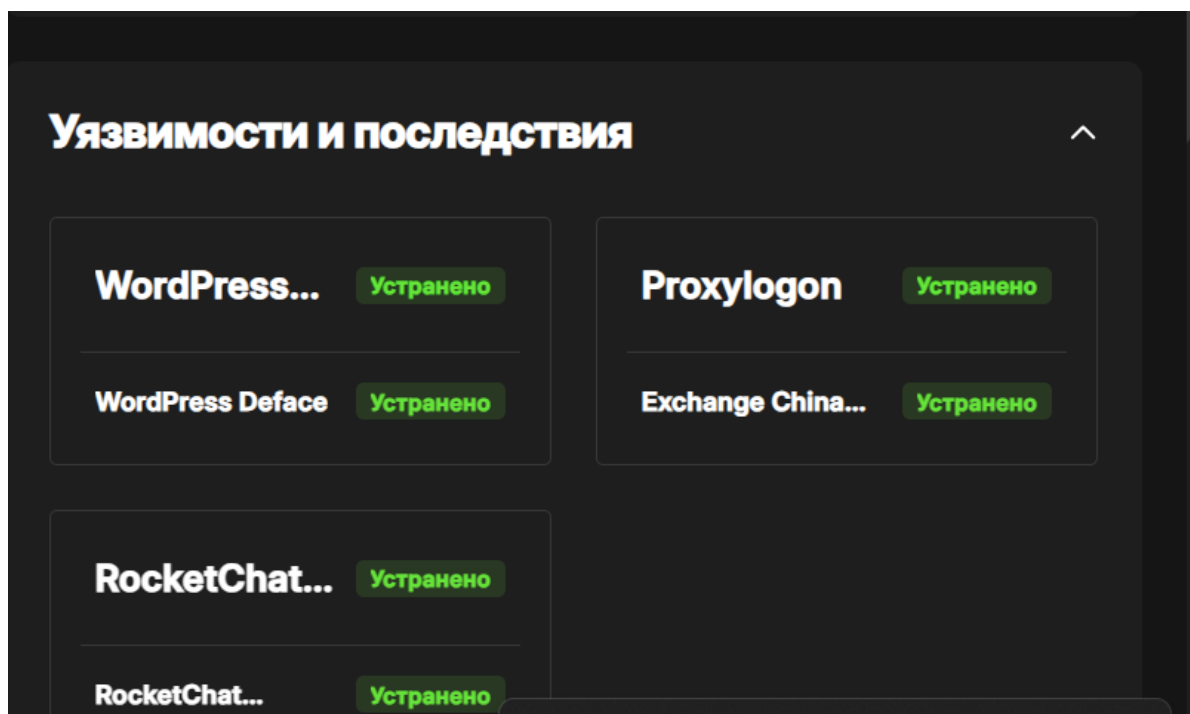


Рис. 5.1: Выполнение работы

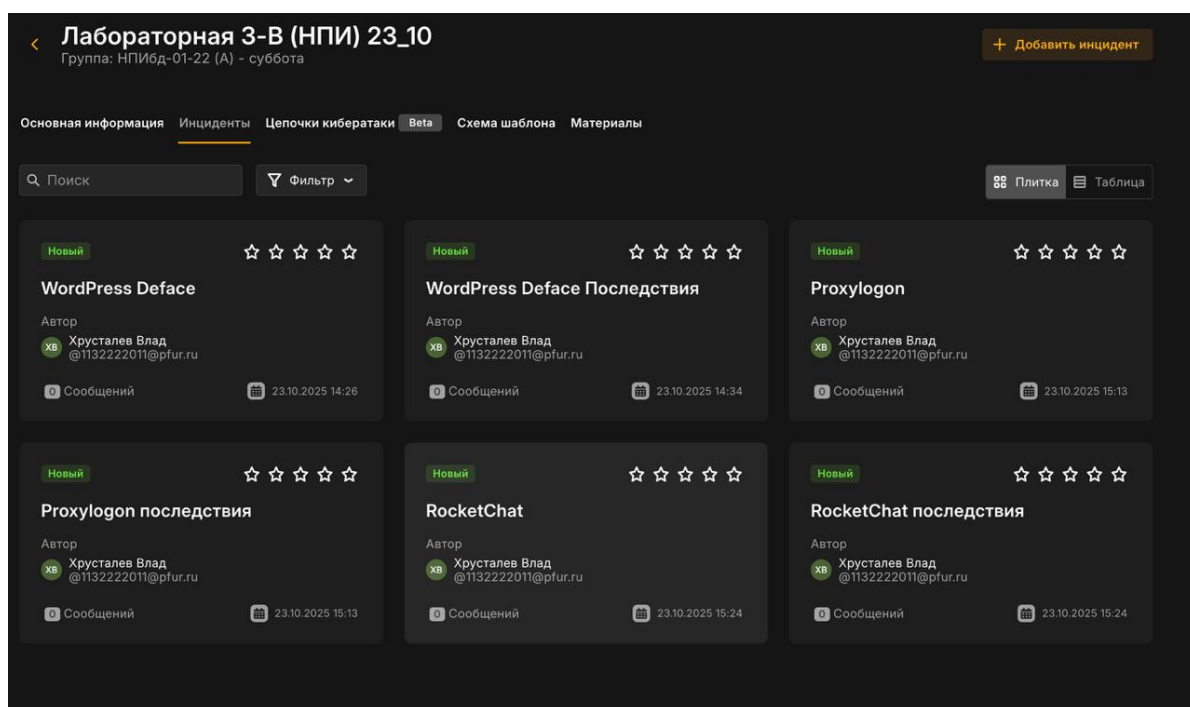


Рис. 5.2: Заполнение инцидентов